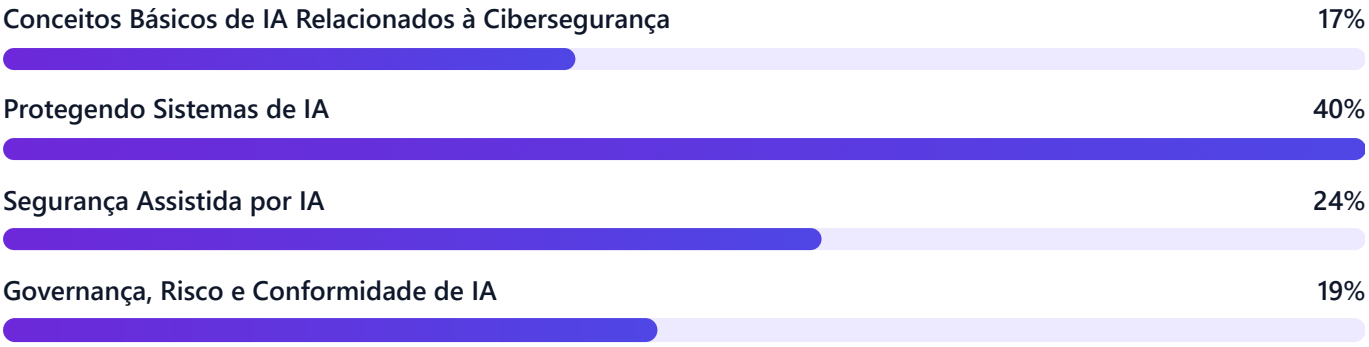
Strecht Simulados

Resumo de bolso CompTIA SecAI+

Domínios cobrados, as dicas de prova mais importantes e 10 questões comentadas para treinar.

360	6	67%
questões no curso	provas completas	nota de corte

Como é a prova CompTIA SecAI+



Material independente de preparação, sem afiliação ou endosso de CompTIA. As questões são inéditas e não reproduzem a prova real.

Pronto para o exame CompTIA SecAI+?

Treine com as 360 questões em 6 provas completas: tempo do exame, explicação de cada alternativa e link da documentação para revisar.

Ver as 6 provas completas e o cupom do mês →

Dicas de prova por domínio

Protegendo Sistemas de IA

- Tirou o nome, mas deixou CEP e nascimento: anonimização incompleta.
- Rótulo nos metadados decide o que pode entrar no treino.
- Resumo de documento confidencial também é confidencial.
- Sortear respostas e conferir com a fonte: auditoria de alucinações.
- Transferência aberta e arquivo em claro: criptografia em trânsito e em repouso.
- Resposta confiante e falsa: Misinformation.
- Relatório gerado por IA indo para fora: redija o que é sensível.
- Log do gateway de IA no SIEM, correlacionado com identidade e EDR.

Segurança Assistida por IA

- Muitas variações da carga até passar no WAF: geração automatizada de payloads.
- Mesma lógica, forma diferente em cada máquina: ofuscação com IA.
- Resumo gerado por IA para decisão importante: humano confere os fatos.
- Rede industrial previsível: anomalia com monitoramento passivo.
- Domínio com cara de aleatório nunca visto antes: reconhecimento de padrões.
- Assistente de código na nuvem: controle o contexto enviado (segredos e código).
- Relatório pós-incidente gerado por IA: quem atuou revisa antes de enviar.
- Rosto que não existe em cadastro de cliente: identidade sintética gerada por IA.

Conceitos Básicos de IA Relacionados à Cibersegurança

- 'Você é um analista de SOC...' na mensagem de sistema: system role.
- Modelo rodando em paralelo para conferir os critérios de aceite: validação.
- Primeiro o porquê: caso de uso alinhado ao negócio.
- Implantação segura: gradual, monitorada e sem portas de depuração.
- Acurácia medida nos dados de treino não vale: avalie com dados separados.
- Um exemplo resolvido no prompt: one-shot.
- Tabela fixa: estruturado. JSON e XML: semiestruturado. Texto livre e imagem: não estruturado.
- Vários exemplos no prompt: multi-shot. Um: one-shot. Nenhum: zero-shot.

Governança, Risco e Conformidade de IA

- Ferramenta de IA usada sem aval da empresa: Shadow AI.

- Chatbot na UE: avise que é IA (transparência, artigo 50).
- Ninguém sabe quais IAs existem: crie o inventário obrigatório.
- Dado confidencial exposto sem má-fé, por automação de IA: vazamento acidental.
- Modelo funcionando, mas errando mais: risco de acurácia e desempenho.
- Recrutamento, crédito, educação e infraestrutura crítica: alto risco na Lei de IA da UE.
- Deepfake publicado na UE: informe que é conteúdo artificial.
- Contar que usa IA, para quê e com quais limites: transparência.

10 questões para treinar

Responda antes de olhar o gabarito, no fim do material.

Questão 1 · Protegendo Sistemas de IA

Uma empresa vai escolher entre três modelos de linguagem para um assistente de RH. Antes de decidir, a equipe roda os três em um conjunto padronizado de testes que mede acurácia nas respostas de políticas internas, resistência a jailbreaks, vazamento de dados pessoais e respostas enviesadas. Qual controle de modelo está sendo aplicado?

A. Quantização dos três modelos para comparar o tamanho
B. Avaliação de modelo com critérios de segurança e qualidade
C. Rate limit por usuário no gateway de IA da empresa
D. Prompt firewall com regras de bloqueio por palavra-chave em produção

Questão 2 · Protegendo Sistemas de IA

Uma plataforma de RAG atende vários clientes corporativos com um único banco vetorial compartilhado. Durante um teste, uma pergunta feita por um usuário do cliente A retornou trechos de contratos do cliente B. Em qual categoria do OWASP Top 10 para aplicações LLM (2025) esse risco se encaixa?

A. Improper Output Handling
B. Unbounded Consumption
C. Data and Model Poisoning
D. Vector and Embedding Weaknesses

Questão 3 · Protegendo Sistemas de IA

Um agente de IA que ajuda a equipe de infraestrutura a analisar logs recebeu, por conveniência, uma ferramenta de shell genérica no servidor. Após ler um arquivo de log manipulado por um atacante, o agente executou um comando que criou um usuário local com privilégios. Qual controle compensatório reduz o impacto desse tipo de ataque?

A. Trocar o shell genérico por ferramentas específicas com privilégio mínimo
B. Registrar as conversas do agente em um arquivo de texto local
C. Aumentar a janela de contexto para que o agente consiga ler os logs inteiros
D. Aplicar quantização ao modelo do agente para respostas mais rápidas

Questão 4 · Segurança Assistida por IA

Um relatório de inteligência descreve um criminoso com pouca experiência técnica que usou um LLM sem restrições para montar, em poucos dias, um ransomware funcional com rotina de criptografia e propagação. Qual efeito da IA sobre o cenário de ameaças esse caso ilustra?

A. Geração automatizada de malware que reduz a barreira de entrada
B. Redução da superfície de ataque das empresas atacadas
C. Watermarking de arquivos maliciosos para identificar o autor do ransomware
D. Aumento da privacidade diferencial dos dados das vítimas

Questão 5 · Protegendo Sistemas de IA

Uma empresa treinou um assistente de suporte com milhares de tickets antigos, sem tratamento prévio. Em testes, um usuário pediu 'exemplos de tickets sobre troca de endereço' e o modelo respondeu com nomes, endereços e telefones reais de clientes. Qual vulnerabilidade foi explorada e qual controle ataca a causa?

A. Model theft, com rate limiting nas consultas feitas ao assistente
B. Model DoS, com limite de tokens nas respostas do assistente de suporte
C. Model skewing, com validação do feedback enviado pelos usuários
D. Divulgação de informação sensível, com sanitização dos dados antes do treino

Questão 6 · Segurança Assistida por IA

Uma equipe de segurança quer que seu assistente de IA consulte o SIEM, a base de ativos e o sistema de tickets por meio de uma interface padronizada, sem criar uma integração proprietária para cada ferramenta. Qual tecnologia atende a esse cenário?

A. Plug-in de navegador com assistente de IA
B. Chatbot público de IA generativa
C. Servidor MCP (Model Context Protocol)
D. Banco vetorial com embeddings

Questão 7 · Protegendo Sistemas de IA

Uma empresa validou os guardrails do seu assistente antes do lançamento. Desde então, trocou a versão do modelo base, alterou o system prompt duas vezes e adicionou um conector de e-mail, sem repetir nenhum teste. Qual prática de teste e validação de guardrails está faltando?

A. Trocar os testes adversariais por uma revisão do texto do system prompt
B. Testar os guardrails uma única vez, antes do primeiro lançamento do produto
C. Repetir os testes adversariais a cada mudança relevante
D. Testar os guardrails só depois que algum cliente relatar um incidente grave

Questão 8 · Segurança Assistida por IA

Quando um alerta vira ticket de incidente, os analistas gastam até 20 minutos buscando o dono do ativo, vulnerabilidades conhecidas, indicadores em threat intelligence e incidentes parecidos. A empresa quer usar IA no sistema de tickets para reduzir esse tempo. Qual uso é mais adequado?

A. Trocar a descrição do alerta por um texto gerado sem as evidências originais
B. Enriquecer o ticket com ativos, vulnerabilidades, inteligência e casos parecidos
C. Gerar tickets duplicados para cada fonte consultada pela IA
D. Fechar o ticket quando a IA não encontrar contexto suficiente sobre o ativo afetado

Questão 9 · Segurança Assistida por IA

Analistas do SOC de uma rede de farmácias criaram, em uma plataforma no-code, um fluxo que envia cada alerta a um LLM e bloqueia no firewall os IPs que o modelo considerar maliciosos. O fluxo não passou por revisão e usa uma credencial de administrador do firewall. Qual é a correção mais importante?

A. Migrar o fluxo para uma plataforma low-code com mais conectores
B. Submeter o fluxo à revisão e usar uma credencial com privilégio mínimo
C. Trocar o LLM por um modelo maior para reduzir os falsos positivos
D. Aumentar a frequência de execução do fluxo para reagir mais rápido

Questão 10 · Protegendo Sistemas de IA

Uma equipe vai configurar o fluxo de uma requisição no gateway de IA corporativo. Qual ordem de controles é a mais adequada?

A. Prompt firewall, modelo, autenticação, registro, guardrail de saída, rate limit e cotas
B. Autenticação, rate limit e cotas, prompt firewall, modelo, guardrail de saída e registro
C. Modelo, guardrail de saída, autenticação, prompt firewall, rate limit e cotas e registro
D. Registro, modelo, rate limit e cotas, guardrail de saída, prompt firewall e autenticação

Gabarito comentado

1. B) Avaliação de modelo com critérios de segurança e qualidade
Comparar modelos com bateria de testes de segurança e qualidade: avaliação de modelo.

2. D) Vector and Embedding Weaknesses
Banco vetorial compartilhado devolvendo dado de outro cliente: Vector and Embedding Weaknesses.

3. A) Trocar o shell genérico por ferramentas específicas com privilégio mínimo
Agente com shell genérico é agência excessiva: ferramentas específicas e privilégio mínimo.

4. A) Geração automatizada de malware que reduz a barreira de entrada
IA ajudando novatos a criar malware: menor barreira de entrada.

5. D) Divulgação de informação sensível, com sanitização dos dados antes do treino
Modelo devolvendo dado real de cliente: divulgação de informação sensível.

6. C) Servidor MCP (Model Context Protocol)
Interface padrão entre o assistente de IA e as ferramentas: servidor MCP.

7. C) Repetir os testes adversariais a cada mudança relevante
Mudou modelo, prompt ou integração: teste os guardrails de novo.

8. B) Enriquecer o ticket com ativos, vulnerabilidades, inteligência e casos parecidos
Ticket chega com contexto pronto: enriquecimento com IA.

9. B) Submeter o fluxo à revisão e usar uma credencial com privilégio mínimo
Automação no-code com IA: revisão e privilégio mínimo como qualquer código.

10. B) Autenticação, rate limit e cotas, prompt firewall, modelo, guardrail de saída e registro
Gateway: quem é, quanto pode, o que pede, o que o modelo responde e registro.

Pronto para o exame CompTIA SecAI+?

Treine com as 360 questões em 6 provas completas: tempo do exame, explicação de cada alternativa e link da documentação para revisar.

Ver as 6 provas completas e o cupom do mês →